

Uyum ve Klinik Güvenlik Kontrol Listesi — Uzm. Dr. Oğuz Bak

Bu belge, platformun Türkiye'de yasal olarak yayına alınması ve en yüksek hukuki / klinik / itibar risklerini azaltmak için klinik sahibinin imzalaması, yapması, asması veya klinik uygulamada değiştirmesi gereken her şeyi içerir. Atıfta bulunulan tüm süreler ve ceza tavanları **Mayıs 2026** itibarıyla günceldir.

İngilizce karşılığı: docs/compliance/CHECKLIST-DOCTOR.md Yazdırılabilir PDF sürüm: docs/compliance/dr-bak-uyum-listesi.pdf

Yayına En Geç Kalan 10 Kritik Madde

Atlanması durumunda hukuki, klinik veya itibar zararı en yüksek olandan başlayarak sıralanmıştır.

- Telesağlık başlamadan önce İl Sağlık Müdürlüğü'nden Uzaktan Sağlık Faaliyet İzin Belgesi alın.** Belgesiz yapılan her telesağlık seansı yasadışı uygulamadır; Bakanlık hizmeti durdurabilir ve Cumhuriyet Savcılığına suç duyurusunda bulunabilir. Başvuru için en az 30 gün ayırın.
- 72 saatlik veri ihlali müdahale sürecini hazırlayın ve test edin.** 2026 KVKK ceza tavanı ihlal başına **17.092.242 TL**'dir; GDPR ayrıca paralel bir tavan koyar: **€20M veya küresel cironun %4'ü, hangisi yüksekse**. AB'de yerleşik hastalar etkilendiğinde aynı 72 saat içinde **hem Kurul'a hem de yetkili bir AB DPA'sına** bildirim zorunludur. Geç bildirim, her iki rejim için de en sık verilen cezadır.
- İlk hasta kaydından sonraki 30 gün içinde VERBİS kaydını yapın** ve bir irtibat kişisi atayın. 2025/1572 sayılı Kurul kararının istisna kapsamı sadece <10 çalışan VE <10 milyon TL bilanço ölçeğindeki mikro klinikleri içerir. **Ayrı olarak, ilk ücretli AB randevusunu kabul ettiğinizde GDPR md.27 AB temsilcisi atayın** — bkz. §B9.1.
- Tüm hasta verilerini AB / Frankfurt bölgesine sabitleyin; her sınır ötesi tedarikçi ile Standart Sözleşme imzalayın ve imzayı izleyen 5 iş günü içinde KVKK'ya bildirin.** Mart 2024 öncesindeki "yurt dışı aktarımı için açık rıza" yolu artık rutin akışlar için geçerli değildir. AB'de yerleşik hastaların verisi Frankfurt'a aktığında bu AEA-içi olduğundan GDPR Bölüm V karşılanır; KVKK md.9'un düzenlediği şey, **Türkiye ayağıdır** (siz İstanbul'dan veriye eriştiğinizde).
- Granüler ve ayrı açık rızalar** — asla paket halinde değil. Her amaç için ayrı bir kayıt: tedavi / telesağlık / yurt dışı aktarım / pazarlama. Paket rıza otomatik olarak geçersizdir; ispat yükü kliniğindir.
- Joint Commission + ISMP "Kullanılmayacak Kısaltmalar" listesini** her kanalda uygulayın — kağıt reçete, e-Reçete serbest metni, WhatsApp, taburcu notları. Tek bir insülin "U → 0" hatası veya kuyruk-sıfır doz aşımı, **TCK md.85 (taksirle yaralama / öldürme)** kapsamında cezai sorumluluk doğurur.
- Tıbbi kayıtlar için 20 yıllık saklama süresi** — telesağlık notları dahil — ve bu kapsamın dışında kalan veriler için otomatik imha boru hattı.
- Telesağlık onam metni, Yönetmelik md.7'deki açıklamaları aynen** içermelidir; hastanın dilinde, atlanamayan modal pencerede ve e-imzayla onaylanmalı.
- KVKK md.11 ve GDPR md.15–22 hasta talepleri için 30 gün / 1 ay yanıt süresi.** Takip edilebilir bir başvuru adresi (kvkk@drbak.com) ve hazır bir yanıt şablonu kurun. AB'de yerleşik hastalar, KVKK'da bulunmayan iki ek hakka sahiptir — **veri taşınabilirliği (md.20)** ve **kısıtlama (md.18)** — her ikisi de mutlaka karşılanmalı. Geç veya cevapsız kalmak başlı başına her iki rejimde de ceza ihlalidir.

10. **Özel nitelikli verilere ait her okuma/yazma için ekleme-yalnızca audit log;** en az 10 yıl saklanmalı; kişisel olarak imzaladığınız üç aylık erişim incelemesi yapılmalı.
-

B1. Yayın Öncesi Bir Kez Yapılacaklar

B1.1 — VERBİS kaydı

Aşağıdaki üç koşulu aynı anda sağlamadığınız sürece kayıt zorunludur: <10 çalışan, <10 milyon TL bilanço, ana faaliyetin sağlık verisi işlemek olmaması. Özel psikiyatri / TMS muayenehanesi olduğunuz için sağlık verisi işlemek ana faaliyetinizdir; bu nedenle ölçek ne olursa olsun kayıt gereklidir.

- **Süre:** İlk hasta kaydından itibaren 30 gün
- **Yer:** <https://verbis.kvkk.gov.tr>
- **Kim:** Şahsen siz, veya atadığınız bir irtibat kişisi

B1.2 — İrtibat Kişisi atama

Tek hekimli muayenehanede bu kişi siz olabilirsiniz. KVKK, klinik ölçeğinde GDPR tarzı resmi bir DPO talep etmez; ancak VERBİS'e bir irtibat kişisi bildirmeniz **zorunludur**.

B1.3 — Uzaktan Sağlık Faaliyet İzin Belgesi başvurusu

Belge olmadan tele sağlık yapılamaz. Gerekli belgeler:

- Mevcut muayenehane / poliklinik ruhsatı
- Entegre olacağınız USBS (Uzaktan Sağlık Bilgi Sistemi) — Bakanlık siciline kayıtlı olmalı
- Yönetmelik Ek-1 formları
- **Başvuru:** İstanbul İl Sağlık Müdürlüğü
- **Karar süresi:** ≤15 iş günü
- **Kaynak:** RG 10.02.2022/31746, Uzaktan Sağlık Yönetmeliği md.6 (<https://www.resmigazete.gov.tr/eskiler/2022/02/20220210-2.htm>)

B1.4 — Veri İşleyen Sözleşmeleri

Hasta verisine dokunan her tarafla yazılı sözleşme zorunludur: - Yazılım geliştirme ekibi - Cloudflare (barındırma + Workers + R2 depolama + video) - Neon (Postgres veritabanı, Frankfurt) - Meta (WhatsApp Business API) - İyzico (ödeme altyapısı) - Resend (e-posta gönderimi) - NetGSM / Twilio (SMS) - Jitsi (görüntülü görüşme) - Hata izleme veya analitik tedarikçisi varsa hepsi

Asılları saklayın. Kurul herhangi bir denetimde bu sözleşmeleri talep eder.

B1.5 — Aydınlatma Metni

İki versiyon hazırlanmalı:

- **Bekleme odası poster** — Türkçe
- **Web / uygulama versiyonu** — TR / AR / EN / FR / ES dillerinde

Zorunlu içerik (KVKK Aydınlatma Yükümlülüğü Tebliği): - Toplanan veri kategorileri - İşleme amaçları - Hukuki sebepler (KVKK md.5/2 + md.6) - Aktarılan üçüncü taraflar (tedarikçiler, kamu otoriteleri) - Yurt dışı aktarım hedefleri - Saklama süreleri - İletişim bilgileriniz - Hastanın md.11 hakları, sade dilde

B1.6 — İmzalanması zorunlu yazılı politikalar

Kurul, denetimlerde bu belgeleri görmek ister:

1. **Kişisel Veri Saklama ve İmha Politikası** (VERBİS'e kayıtlıysanız zorunlu)
2. **Özel Nitelikli Kişisel Veri Politikası** (Karar 2018/10 zorunluluğu)
3. **Erişim Yetki Matrisi** (kim neyi görebilir tablosu)
4. **Veri İhlali Müdahale Planı**
5. **Çalışan Gizlilik Taahhütnamesi** (her personel ayrı ayrı imzalar)

B2. Toplanması zorunlu açık rızalar — ayrı ayrı, asla paket halinde değil

B2.1 — Tedavi Onamı

Standart psikiyatri / TMS aydınlatılmış onamı. Sizin için zaten rutin; metnin KVKK md.6 ve Kişisel Sağlık Verileri Yönetmeliği md.5'i açıkça referans aldığından emin olun.

B2.2 — Telesağlık Onamı

Uzaktan Sağlık Yönetmeliği md.7'deki açıklamaları **aynen** içermelidir: - Hekimin kimliği ve uzmanlık alanı - Hasta ile hekimin aynı fiziksel mekânda olmadığı - Telesağlık'ın yüz yüze tedavi ile **eşdeğer olmadığı** - Devam eden fiziksel tedavilerin yerini almadığı - Acil durumlarda hastanın **112**'yi araması gerektiği - Ücret ve sigorta durumu - **Seans başına açık rıza alınmadan kayıt yapılamayacağı**

İlk telesağlık başvurusundan önce hasta tarafından e-imza ile onaylanmalı. Metin hastanın dilinde sunulmalı.

B2.3 — Yurtdışı Aktarım Bilgilendirmesi

Hastayı, platformun Almanya'da Standart Sözleşme kapsamında barındırıldığı konusunda bilgilendirir.

Haziran 2024 KVKK değişikliklerinden sonra bu bir **bilgilendirmedir, başlı başına hukuki sebep değildir** — gerçek hukuki sebep, her AB tedarikçisi ile imzalanan Standart Sözleşmedir (B1.4).

B2.4 — Pazarlama Açık Rızası

Sadece pazarlama amaçlı SMS / e-posta gönderecekseniz. **Varsayılan KAPALI**. Açık rıza alınmadan hatırlatma veya takip mesajlarına pazarlama içeriği **eklemeyin**.

B2.5 — TMS özel kontrendikasyon kontrol listesi

Onam paketi ile birlikte tek seferde imzalanmalı: epilepsi öyküsü, ferromanyetik implant, gebelik, mevcut ilaçlar, geçirilmiş beyin cerrahisi.

B3. Hasta talep yönetimi (KVKK md.11)

Hasta, yazılı olarak (fiziksel, e-posta veya platform iletişim formu üzerinden) aşağıdakilerden herhangi birini istediğinde:

- Verisinin işlenip işlenmediğinin teyidi
- İşleme amaçları
- Verinin paylaşıldığı tarafların listesi

- Yanlış verinin düzeltilmesi
- Verinin silinmesi
- Yurt dışı aktarım hakkında bilgi

Cevap vermek için süreniz **30 gündür** ve cevap ücretsizdir.

- Eğer silmeniz mümkün değilse (örn. 20 yıllık saklama yükümlülüğü nedeniyle), silmeyi engelleyen mevzuat maddesini VE silmenin mümkün olacağı tarihi yanıtta belirtin.
- Geç veya yetersiz cevap → hasta Kurul'a şikayette bulunabilir. Geç cevap kendi başına ceza ihlalidir.
- Tek bir başvuru adresi (kvkk@drbak.com) belirleyin ve her talebi takip edilebilir bir kuyruğa yönlendirin.

Kaynak: KVKK md.13 + İlgili Kişi Başvuru Tebliği.

B4. Saklama süreleri

Kayıt türü	Saklama süresi	Kaynak
Hasta dosyası (telesağlık notları, reçeteler, tetkikler, TMS protokol parametreleri dahil)	20 yıl son temastan itibaren (reşit olmayanlar için: 18 yaş + 20 yıl)	Hasta Hakları Yönetmeliği
Aydınlatılmış onam belgeleri	20 yıl, hasta dosyası ile birlikte	KVKK + Hasta Hakları
Audit log (kim hangi kayda erişti)	En az 10 yıl	Karar 2018/10
İmha tutanakları	Süresiz	İmha Yönetmeliği
Reçete (e-Reçete)	e-Reçete sisteminde tutulur; kağıt nüsha saklanmaz	Sağlık Bakanlığı
Fatura / makbuz	10 yıl	VUK + TTK md.82
Pazarlama açık rıza kaydı	Geri alınana kadar + 3 yıl	Açık Rıza Rehberi
WhatsApp / chatbot mesajları (sağlık şikayeti içeriyorsa)	Sağlık verisi olarak — 20 yıl	Yönetmelik md.5

Hastanın o anda gördüğü Aydınlatma Metni ve onam formlarının **o tarihteki versiyonunu** muhafaza edin — sadece güncel sürümü değil.

B5. Veri ihlali olduğunda

Sayaç, ihlalin makul bir kesinlikle öğrenildiği anda başlar. **Soruşturma tamamlandığında değil.**

- **72 saat** içinde Kurul'a **İhlal Bildirim Formu** (<https://www.kvkk.gov.tr/Icerik/5362/Veri-Ihlali-Bildirimi>) ile bildirim. Geç = otomatik ceza.
- Etkilenen hastalara "en kısa süre içinde" doğrudan bildirim — e-posta + SMS; toplu olay olur ve iletişim bilinmiyorsa, ayrıca web sitesinde duyuru.
- AB'de yerleşik hastalar etkilenmişse, GDPR md.33 uyarınca yetkili bir AB Veri Koruma Otoritesine de bildirim — aynı 72 saat.
- **Olayı kamuoyu önünde küçümsemeyin.** Kurul, bildirilmemiş ihlalleri klinik adıyla birlikte Kamuoyu Duyuruları olarak yayınlar.

- İç olay raporu hazırlayın: sebep, kapsam, alınan tedbirler, çıkarılan dersler.

Kaynak: KVKK Karar 2019/10.

B6. Telesağlık — kayıtların asgari içeriği

Her uzaktan konsültasyon için:

1. Görüntülü görüşme **başlamadan önce** hasta kimliği doğrulanmalı (TC kimlik vatandaşı için, pasaport yabancı hastalar için).
 2. Aydınlatma + onam, seans öncesi alınmış ve kanıtlanabilir olmalı.
 3. Görüşme, kayıtlı USBS aracılığıyla Bakanlık zaman dilimleri içinde **e-Nabız**'a aktarılmalı.
 4. Hasta o seans için açıkça izin vermediği sürece **kayıt yapılmamalı**.
 5. İlaç önerirseniz **yalnızca e-Reçete** kullanın. WhatsApp üzerinden kağıt reçete fotoğrafı **göndermeyin**.
 6. En azından yüz yüze muayenedeki kadar dolu doldurulmalı; ayrıca "uzaktan" notu işlenmeli.
-

B7. Reçete ve hekim notu güvenliği — bu kısaltmaları asla kullanmayın

Bu kısaltmalar, dünyada en sık görülen ölümcül ilaç hatalarının kaynağıdır. Joint Commission ve ISMP tarafından yasaklanmıştır. **e-Reçete sistemi ilaç adlarını zorlar ama doz işaretlerinin tüm tuzaklarını engellemez** — risk, serbest metin notlarınızda, hastaya WhatsApp'ta verdiğiniz talimatlarda ve taburcu özetlerinde gizlidir.

Yazmayın	Neden tehlikeli	Bunun yerine yazın
U veya u	"0" olarak okunur → 10× insülin doz aşımı	"ünite"
IU	"IV" veya "10" olarak okunur	"uluslararası ünite"
QD / q.d.	"QID" olarak okunur → 4× doz	"günde bir kez"
QOD	"QID" veya "QD" olarak okunur	"gün aşırı"
MS / MSO4	Morfin sülfat ile magnezyum sülfat karıştırılır	"morfin sülfat"
MgSO4	MSO4 ile karıştırılır	"magnezyum sülfat"
cc	"U" olarak okunur	"mL"
µg (Yunan harfi mu)	"mg" sanılır → 1000× hata	"mcg"
kuyruk sıfırı "1.0 mg"	Nokta atlanır → 10× doz aşımı	"1 mg"
çiplak ondalık ".5 mg"	Nokta atlanır → 10× doz aşımı	"0,5 mg"
HS	"yarım doz" mı yoksa "yatmadan önce" mi belirsiz	"yatmadan önce"
D/C	"discharge" mı "discontinue" mı belirsiz	açık yazın
AD / AS / AU	Sağ / sol / her iki kulak — göz koduyla karışır	"sağ kulak" / "sol kulak" / "her iki kulak"
OD / OS / OU	Sağ / sol / her iki göz — kulak koduyla karışır	açık yazın
BT	"yatma" mı "biyopsi" mi belirsiz	"yatarken"
SC / SQ	"SC" → "SL"; "SQ" → "5 her"	"subkutan"
PO (el yazısı)	Sol göz olarak okunabilir	"ağızdan" / "oral yolla"
@	"2" olarak okunur	"saat" veya tam yazın
> <	Tersi olarak veya harf olarak okunabilir	"büyüktür" / "küçüktür"
eğik çizgili doz "25/50 mg"	Eğik çizgi "1" olarak okunur → 25.150 mg	"ve"
AZT / HCT / 6-MP / MTX	İlaç adı kısaltmaları	her ilaç adını açık yazın
NAS intranazal için (2024)	Yanlış okunur	"intranazal"

Türkiye'ye özgü notlar:

- Dozları **her zaman önde sıfır** ile yazın: "0,5 mg" — ve aynı belgede ondalık ayıracını tutarlı kullanın (aynı çizelgede "0.5" ile "0,5" karıştırılmamalı).
- Türk pazarında benzer isimli markalar (Lustral / Lustragen, Cipram / Cipro, Xanax / Zofran) için ilk geçişte **jenerik + marka** birlikte yazın: "essitalopram (Ciprallex)".
- Hastaya WhatsApp talimatında: ilaç adını, dozu ve sıklığı **tam Türkçe** yazın — tıbbi kısaltma kullanmayın.

Kaynaklar: Joint Commission Do Not Use Listesi (<https://www.jointcommission.org/en-us/knowledge-library/support-center/standards-interpretation/do-not-use-list-of-abbreviations>); ISMP 2024 Listesi (https://www.ismp.org/system/files/resources/2024-04/ISMP_Err)

B8. Birisi önerirse reddedeceğiniz öneriler

- **"ABD sunucusunda barındırılım, daha hızlı."** — KVKK md.9 incelemesi + Standart Sözleşme şart. Frankfurt uygundur; Virginia, SCC veya BCR olmadan değildir.
 - **"Telesağlık seanslarını varsayılan olarak kaydedelim."** — Yönetmelik md.7/g uyarınca seans başına açık rıza alınmadan **yasadışıdır**.
 - **"Tetkik PDF'ini WhatsApp Business üzerinden gönderelim."** — Sadece platform üzerinden, süresi dolan link ile. WhatsApp mesaj gövdesi Meta sunucularında saklanır ve özel nitelikli içerik için bu kanal hakkında SCC'niz / eşdeğer sözleşmeniz yoktur (açık rıza istisnası dışında).
 - **"Telesağlık + tedavi + pazarlama rızalarını tek kutuda toplayalım."** — Geçersiz; KVKK Açık Rıza Rehberi granüler ve özel rıza talep eder.
 - **"VERBİS'i atlayalım, küçüğüz."** — Ölçeğiniz kayıt yükümlülüğünü tetikler; Kurul'un VERBİS-eksikliği cezaları rutin olarak yüksek altı haneli TL'dir, 2026 tavanı 17M TL.
-

B9. GDPR — Avrupa hastaları için (FR / ES / EN dilleri)

GDPR'nin **md.3(2)** kapsamı kliniği bağlar: platform FR/ES/EN dillerinde hizmet sunduğu, EUR fiyatlandırması yaptığı ve AB'de yerleşik hastalardan randevu kabul ettiği için — klinik ve sunucular AB dışında olsa da. Bu bir **"bağlayıcı"** durumdur, opsiyonel değildir.

İyi haber: GDPR ve KVKK büyük ölçüde örtüşür. KVKK uyumunu doğru yapın, GDPR'nin ~%85'i otomatik karşılanır. Aşağıdaki maddeler, GDPR'nin **fazladan veya farklı** bir şey istediği boşlukları gösterir.

B9.1 — AB Temsilcisi (md.27)

Zorunlu sebebi: (a) AB'de yerleşik hastaların özel-nitelikli sağlık verisini işliyorsunuz; (b) işleme düzenlidir, ara sıra değildir. Temsilci, AB veri koruma otoriteleri (DPA) ve veri sahipleri için iletişim noktanızdır.

- **Kim:** AB'de yerleşik bir hukuk firması veya uzman DPO-hizmeti sağlayıcı (sizin ölçeğinizdeki klinik için tipik maliyet **€500–€2.000 / yıl**).
- **Nerede yayınlanacak:** Aydınlatma Metni'nde — temsilcinin adı + adresi, herhangi bir AB ülkesinden ulaşılabilir.
- **Atlamanın mümkün olduğu durum:** AB hasta hacminiz **ihmal edilebilir VE ara sıra ise**. İlk ücretli AB randevusunu kabul ettiğiniz an yükümlülük başlar.

B9.2 — Yetkili (lead) DPA

Klinik AB'de kurulu olmadığı için "lead DPA" yoktur — her AB üye devletinin DPA'sı bağımsız hareket edebilir. Pratik kural: en çok hastanızın bulunduğu ülkenin DPA'sını Aydınlatma Metni'nde **birincil temas noktası** olarak isimlendirin, ancak herhangi bir AB DPA'sından şikayet alabileceğinizi öngörün.

B9.3 — Hasta hakları — KVKK md.11 ile aynı liste, biraz farklı süreler

Hak (GDPR maddesi)	KVKK karşılığı	Süre
Erişim (md.15)	md.11/b-c	1 ay (karmaşık talepler için +2 ay uzatılabilir, bildirim şartıyla)
Düzeltilme (md.16)	md.11/d	1 ay
Silme / "unutulma hakkı" (md.17)	md.11/e	1 ay — engel: yasal saklama yükümlülüğü veya kamu yararına tıbbi araştırma
Kısıtlama (md.18)	—	1 ay — KVKK'da doğrudan karşılığı yok ; AB hastaları için uygulayın
Veri taşınabilirliği (md.20)	—	1 ay — KVKK'da karşılığı yok. AB hastaları, verilerinin makine-okunabilir formatta dışa aktarımını talep edebilir. Bunu sağlayın.
İtiraz (md.21)	md.11/f	1 ay
Açık rızayı geri çekme (md.7(3))	Açık Rıza Rehberi	Talep anında derhal etkili

Operasyonel çözüm: tüm hasta-hakkı taleplerini aynı kvkk@drbak.com kuyruğuna yönlendirin. AB'de yerleşik hastalardan gelenleri etiketleyin ki GDPR-özel süreler ve haklar (özellikle KVKK'nın talep etmediği taşınabilirlik ve kısıtlama) işlesin.

B9.4 — Veri ihlali bildirimi — her iki rejimde de 72 saat, ama AB tarafında çift hedef

İhlal AB'de yerleşik hastaları etkiliyorsa, **hem KVKK Kurul'a hem de yetkili bir AB DPA'sına** 72 saat içinde bildirim zorunludur. İhlal etkilenen kişiler için "yüksek risk" oluşturuyorsa, doğrudan bildirim de gecikmesiz yapılmalı (md.34). KVKK aynısını talep eder; ikisini birden karşılayan tek bir bildirim şablonu kullanın.

B9.5 — Çerez ve izleme — ePrivacy Direktifi

GDPR kişisel veri içindir; AB trafiğinde çerez izni ePrivacy Direktifi kapsamındadır. Pratik kurallar:

- **Varsayılan olarak yalnızca kesinlikle gerekli çerezler** — oturum, CSRF, dil tercihi. Bunlar için izin gerekmez.
- **Analitik, pazarlama, üçüncü taraf izleyiciler — yalnızca opt-in**, doğru şekilde reddedilebilir bir izin banner'ı arkasında. **"Tümünü reddet"** butonu **"Tümünü kabul et"** kadar belirgin olmalı (CJEU içtihadı ve EDPB kılavuzu).
- **Önceden işaretli kutular geçersizdir** — hem ePrivacy hem KVKK Karar 2020/559 uyarınca.

B9.6 — Veri Koruma Etki Değerlendirmesi (DPIA — md.35)

İşleme "yüksek risk" doğurması muhtemel ise DPIA zorunludur. Özel-nitelikli sağlık verisi + tele sağlık video + sınır-ötesi aktarım + otomatik chatbot triyajı bunu tetikler. **DPIA'yı yazılım tarafı üretir; siz hukuki inceleme sonrasında onaylarsınız.**

B9.7 — AB hastasından Frankfurt'a sınır-ötesi aktarım

Neredeyse sorun değil: veri akışı AB'de yerleşik hastanın tarayıcısı → CF AB edge → Neon Frankfurt. Tümü AB/AEA içinde. Sınır-ötesi unsur, **Türkiye'de bulunan klinik (siz, İstanbul'dan veriye erişmek)** ile AB'de saklanan veri arasındadır. Bu GDPR Bölüm V kapsamındadır — Standart Sözleşme + KVKK 5-iş-günü dosyalama Türkiye ayağını zaten kapsar.

B9.8 — İşleme Faaliyetleri Kayıtları (RoPA — md.30)

Özel-nitelikli veri işleyen her veri sorumlusu için zorunlu, ölçek farketmez. KVKK VERBİS kaydı içeriğin çoğunu kapsar ama tek başına md.30-uyumlu değildir. md.30'un istediği formatta dahili bir RoPA tutun (şablonu üreteceğiz); hekim yıllık imzalar.

B9.9 — KVKK'dan anlamlı şekilde farklı olanlar

- **Veri taşınabilirliği** — GDPR var, KVKK yok. Uygulanmalı.
- **Kısıtlama hakkı** — GDPR var, KVKK yok. Uygulanmalı.
- **Lead DPA kavramı** — GDPR'da var, KVKK'da yok.
- **md.27 temsilcisi** — GDPR'a özgü; KVKK karşılığı yok.
- **DPIA** — GDPR yüksek-risk için zorunlu kılar; KVKK Karar 2018/10 sadece "yeterli teknik ve idari tedbirler" der, DPIA formatını dayatmaz.
- **AB'de yerleşik hastalar md.79 uyarınca size kendi ülkelerinin mahkemesinde dava açabilir** — pratik hukuki yetki riski. Malpraktis / siber poliçenizin AB forum coğrafyasını kapsayıp kapsamadığını kontrol edin.

B10. SOC 2 ve ISO 27001 — uluslararası denetim standartları

Sonuç: lansman için zorunlu değil, ancak şimdi bilinçli bir karar vermelisiniz.

B10.1 — Bunlar nedir, sade dilde

- **SOC 1** — Verisi başka şirketlerin finansal tablolarını etkileyen hizmet kuruluşları için bir ABD denetim standardı. Sizi **kapsamaz** (B2C bir klinik başkasının defterlerini etkilemez). Atlayın.
- **SOC 2** — Bağımsız bir denetçinin güvenlik, erişilebilirlik ve gizlilik kontrollerinizin çalıştığını teyit ettiği bir ABD denetim standardı. B2B satış kartı olarak kullanılır; yasal zorunluluk değildir.
- **ISO 27001** — Uluslararası (ISO) bilgi güvenliği yönetim standardı. Türkiye'de **TÜRKAK akreditasyonu** ile tanınır. Türk hastane ihalelerinde ve AB kamu ihalelerinde sıkça istenir.

B10.2 — Karar noktası: ne zaman (eğer hiç)

Yol	Lansmanda?	2. yılda?	Hiç?
SOC 2 Type 2	Hayır — B2C için aşırı	Belki — sadece ABD'li kurumsal / global wellness / ABD'li teleşahlık ortağı anlaşması yaparsanız	TR + AB B2C kalırsanız kabul edilebilir
ISO 27001 (TÜRKAK)	Hayır — ama kontrolleri benimseyin	Tavsiye edilir — B2B'ye geçerseniz (sigorta, hastane ortaklığı, Türkiye'de kurumsal wellness)	Saf B2C kalırsanız kabul edilebilir

B10.3 — Maliyet aralıkları (USD, 2026)

	Yıl 1	Yıl 2+
SOC 2 Type 2 (denetim + hazırlık + araç + iç emek)	\$40.000 – \$120.000	\$25.000 – \$60.000
ISO 27001 (TÜRKAK)	~£250.000–600.000 ≈ \$8.000 – \$19.000	\$3.000 – \$7.000 gözetim denetimi

ISO 27001 Türkiye operasyonu için **yaklaşık 5× daha ucuzdur** ve kontrollerinin %80'i doğrudan SOC 2'ye karşılık gelir — yani önce ISO 27001 alıp sonra ABD anlaşması için SOC 2 eklemek isterseniz, ikinci denetim hızlı ve daha ucuz olur.

B10.4 — Hangi yolu seçerseniz seçin yıllık yapmanız gerekenler

Resmi denetim yapmasanız bile, herhangi bir kurumsal müşterinin tedarikçi due-diligence anketi için aşağıdakiler **gereklidir** (ve çoğu zaten KVKK md.12'den doğar):

1. **Yıllık risk değerlendirmesini imzalayın** (1 sayfa özet, sorumlusu sizsiniz)
2. **Olay müdahale prosedürünü (incident response runbook) yıllık inceleyip onaylayın**
3. **Personel eğitim attestation'ını imzalayın** — her klinik ve idari personel yıllık KVKK + telesağlık gizlilik + kısaltma güvenliği eğitimi alır
4. **Tedarikçi listesini yılda iki kez gözden geçirin** — Cloudflare, Neon, iyzico, WhatsApp, Resend, Twilio, Jitsi — ve sertifikalarının güncel olduğunu teyit edin
5. **Felaket kurtarma testi sonuçlarını imzalayın** — yıllık tatbikat, size 1 sayfa rapor verilir, imzalarsınız

B10.5 — Pratik öneri

Yıl 2'de SOC 2 yerine ISO 27001 hazırlığına başlayın. Sebepler: - Türk hastane ortaklıkları ve AB alıcıları için daha ucuz ve daha geçerli - SOC 2'nin gerektirdiği aynı kontrol disiplini (sonradan ABD anlaşması çıkarsa SOC 2 üzerine eklenebilir) - **ISO 27799** (ISO 27001'in sağlık-sektörü uzantısı) psikiyatri / TMS klinik operasyonları için sektöre özel hikaye sağlar

Yıl 1'de operasyonel disiplinlere odaklanın (B10.4) — bunlar KVKK için zaten gerekli ve sertifikasyon kararı verdiğinizde otomatik olarak ISO 27001 kanıtına dönüşür.

Sizin (hekimin) cevaplaması gereken açık sorular

Uygulama yolunu belirleyen sorular; nihai platform teslimi öncesi cevaplara ihtiyacımız var:

1. **Hangi Bakanlık-kayıtlı USBS'yi kullanacaksınız?** Platformun tamamlayıcı bir kanal olarak mı entegre olacağı yoksa telesağlığın tamamen üçüncü taraf USBS üzerinden mi yürüyeceği bu cevaba bağlı (hukuki sonuç farklı).
2. **Mesleki sorumluluk poliçeniz** siber + KVKK cezalarını + **GDPR cezalarını** + AB forum yetkisini kapsıyor mu? Standart poliçeler regülatör cezalarını çoğunlukla hariç tutar ve coğrafi kapsamı sınırlar.
3. **iyzico veri akışı:** iyzico fişte / makbuzda sağlıkla ilgili bir alan tutuyor mu (örn. işlem açıklaması)? Eğer evetse, iyzico özel-nitelikli veri için veri işleyendir ve sözleşmenin bunu yansıtması şarttır.
4. **AB hasta hacmi tahmini:** ayda birkaç hasta bile olsa md.27 temsilcisi gereklidir. Bütçeyi şimdi ayırmaya (tavsiye edilir) mı yoksa düzenleyici riski kabul etmeye mi karar verin.

5. **Hangi AB DPA'sını birincil temas olarak isimlendireceksiniz** Aydınlatma Metni'nde? Önerimiz: **CNIL (Fransa)** — AB'de en aktif sağlık-sektörü DPA'sı ve Fransızca dil trafiğiniz mevcut.

Anahtar kaynaklar

- KVKK Kanun No. 6698 (konsolide) (<https://mgm.adalet.gov.tr/Resimler/SayfaDokuman/211020191355056698%20KVKK.pdf>)
- Kurul Kararı 2018/10 — Özel nitelikli veri yeterli tedbirler (<https://www.kvkk.gov.tr/Icerik/4110/2018-10>)
- Kurul Kararı 2019/10 — 72 saat ihlal bildirimi (<https://www.kvkk.gov.tr/Icerik/5362/Veri-Ihlali-Bildirimi>)
- Kişisel Sağlık Verileri Hakkında Yönetmelik (RG 21.06.2019/30808) (<https://www.resmigazete.gov.tr/eskiler/2019/06/20190621-3.htm>)
- Uzaktan Sağlık Hizmetlerinin Sunumu Hakkında Yönetmelik (RG 10.02.2022/31746) (<https://www.resmigazete.gov.tr/eskiler/2022/02/20220210-2.htm>)
- USBS Sağlık Bakanlığı kayıt sayfası (<https://kayittescil.saglik.gov.tr/TR-90714/uzaktan-saglik-bilgi-sistemi-usbs.html>)
- KVKK Yurt Dışı Aktarım Rehberi (2024 sonrası) (<https://www.kvkk.gov.tr/Icerik/8142/Kisisel-Verilerin-Yurt-Disina-Aktarilmasi-Rehberi>)
- KVKK Açık Rıza Rehberi (<https://www.kvkk.gov.tr/yayinlar/A%C3%87IK%20RIZA.pdf>)
- Hasta Hakları Yönetmeliği (RG 08.05.2014) (<https://www.resmigazete.gov.tr/eskiler/2014/05/20140508-3.htm>)
- Joint Commission Do Not Use List (<https://www.jointcommission.org/en-us/knowledge-library/support-center/standards-interpretation/do-not-use-list-of-abbreviations>)
- ISMP 2024 Error-Prone Abbreviations List (https://www.ismp.org/system/files/resources/2024-04/ISMP_ErrorProneAbbreviation_List.pdf)
- WHO LASA Aide-Memoire 2007 (https://cdn.who.int/media/docs/default-source/patient-safety/patient-safety-solutions/ps-solution1-look-alike-sound-alike-medication-names.pdf?sfvrsn=d4fb860b_8)

Hazırlayan: drbak yazılım ekibi · Dr. Bak Uyum Listesi · Mayıs 2026